INTERNATIONAL CYBERSECURITY AND DIGITAL FORENSICS ACADEMY
GRC206 Security Awareness Program: Northbridge Logistics
Northbridge Logistics REPORT
GRC206 Assignment

Submission detail	Entry
Student name	Nunoo Annah Frimpomaah
Student ID	2025/GCR/12656
Official email	gcr2512656@students.icdfa.edu.ng
Filename	ICDFA_ GRC206_ Security Awareness_Assignment_2025/GCR/12656
AI assistance	My own work. AI tools (ChatGPT Pro, Gemini, Claude Pro) were used for review, language editing and formatting support.

Introduction and assumptions

This report presents a 12-month security awareness program for Northbridge Logistics. It follows five stages: assess, plan, deliver, measure and improve. The goal is to reduce security incidents caused by human mistakes while keeping the program manageable for a small security team. Every activity focuses on one of the three main risks (R1–R3).

Labels used in this report
Scenario: means information provided in the assignment brief.
Assumption: means details added because the brief did not provide them.
Proposed: means suggested targets or plans. These are not actual results from Northbridge.

Area	Scenario facts	My assumptions
People	800 staff across head office, warehouses and remote sales.	Estimated staff numbers: 450 warehouse/operations, 165 general head office, 110 remote sales, 35 finance and procurement, 40 managers and executives. Warehouses run three work shifts; many warehouse staff use shared terminals and handhelds and have very little time at a desk.
Threats	Recent invoice-fraud attempts; two staff reused passwords after a breach.	The company found the password issue through an alert about leaked passwords, not through a staff report.
Data and systems	The company handles regulated customer data.	Microsoft 365 email with a phishing test tool and a “Report” button; an existing HR online training system (LMS); MFA is used for email but not all business applications; the company does not yet have a password manager.

Area	Scenario facts	My assumptions
Resources	Small security team; modest training budget.	Three-person security team. One person spends about half of their working time leading security awareness. The main new cost will be password manager licences for about 350 users. Warehouse training is delivered with help from supervisors and volunteer Security Champions.

Task 1: Assess

1.1 Three main risks caused by human actions

Risk	Unsafe behaviour	Why it is a priority (scenario evidence)
R1 Invoice and payment fraud (business email compromise)	Changing a supplier's bank details or approving an urgent payment based only on an email or phone call, without checking that the request is genuine.	[Scenario] Recent fake invoice attempts are the main reason for starting this program. A logistics company pays many suppliers and transport companies, so fake invoices can look real. Even one successful fake payment could cause a large loss that may be difficult to recover.
R2 Password reuse and credential compromise	Using the same password for work and personal accounts, failing to report a possible password leak, or entering login details on fake websites.	[Scenario] Two staff reused passwords after a breach. If attackers get a reused password, they may access email, payment processes (R1) or customer information (R3).

Audience (approx. size)	Work context	Needs	Main risks
A. Finance and procurement (35)	Handle invoices, supplier bank detail changes and payments.	Practical training to recognise and check payment requests, with a clear process that allows them to take time before approving payments.	R1, R2
B. Warehouse and operations (450)	Work in shifts, use shared computers and handheld devices, have limited email access and work in noisy areas.	Short talks and visual materials during shift meetings, simple rules for using shared computers and handling documents, and an easy way to report issues without email.	R3, R2

Audience (approx. size)	Work context	Needs	Main risks
C. Remote sales (110)	Use mobile devices, travel often, meet customers and handle customer information.	Short lessons that work on mobile phones, safe use of devices and public Wi-Fi, and how to spot fake customer or delivery messages.	R2, R3, R1
D. Head office general (165)	Office-based HR, customer service, IT and administration staff.	Basic security knowledge, spotting phishing, handling data safely and using the password manager.	R2, R3
E. Managers and executives (40)	Approve payments, influence staff behaviour and may be impersonated by attackers.	Short training sessions to help them understand that they may be targeted and show good reporting behaviour. They should also support the no-blame approach.	R1, R2

1.3 Starting measurements before launch (Month 1)

The baseline will be recorded before training starts. This will make it easier to compare results and see whether the program is working.

Baseline measure	Evidence source
Phishing clicks, credential-submission and report rates (one general phishing test for all email users, audiences A, C, D, E)	Microsoft 365 simulation tool
Number of real suspicious emails reported each month, and the average middle time taken to report them (last 6 months)	Report-button logs, helpdesk tickets
Percentage of supplier bank detail changes checked by calling a trusted number (sample from the last 3 months)	Accounts payable change log, finance audit
MFA enrolment %; leaked-credential and risky sign-in alerts (last 6 months)	Identity provider (e.g. Entra ID) reports
Percentage of shared warehouse computers found unlocked during surprise checks	Supervisors spot-check sheet (2 checks per site)
Types and number of data-handling incidents and human mistakes in the last 12 months	Incident register, DPO breach log
10-question knowledge and culture survey, including “I would feel safe reporting my own mistake”	Online form; paper/QR version at shift briefings

Task 2: Plan

2.1 Measurable goals [Proposed]

#	Objective (target and deadline)	Evidence	Owner
O1 (R1)	By the end of Month 9, every supplier bank detail change must be checked by calling a trusted phone number. No payment should be made to a fake account during Months 1 to 12.	Monthly AP audit sample; fraud loss log	Finance Controller

#	Objective (target and deadline)	Evidence	Owner
O2 (R2)	By the end of Month 12, MFA must be used on all email and remote access accounts. At least 80% of staff in groups A, C, D and E must be actively using the company password manager. Every alert about leaked passwords must be handled within 24 hours.	Identity provider; password manager console	IT Operations Manager
O3 (R3 + reporting)	By the end of Month 12, at least 90% of shared warehouse computers must pass the security checks. Data-handling incidents must reduce by 30% compared with the starting figures. At least 50% of staff must report phishing test messages, and no more than 3% should enter their login details.	Spot-check sheets; incident register; simulation tool	Data Protection Officer (with Security Awareness Lead)

2.2 Sponsor and owners

- Sponsor – Chief Operating Officer (COO). The COO is responsible for the warehouses and daily operations, where most employees work. The COO approves the budget and the no-blame reporting promise, leads the reviews in Months 6 and 12, and helps solve any problems that delay the program.
- Program owner – Security Awareness Lead (security team). This person manages the program and phishing tests, prepares training materials, tracks results and updates the action list.
- The Finance Controller is responsible for O1 and the process for confirming bank detail changes by phone. The IT Operations Manager is responsible for O2, including MFA and the password manager. The Data Protection Officer is responsible for O3 and training on how to handle data safely.
- HR Learning and Development adds the training to the learning system, includes it in new-staff induction and tracks completion. Site managers and shift supervisors give short safety talks and check work areas. About 15 volunteer Security Champions, with at least one at each site and shift, collect feedback and guide their colleagues.

2.3 Topics by audience

Audience	Topics (linked risk)
A. Finance and procurement	How to spot fake invoices and bank detail change requests; how to confirm requests by calling a trusted number; fake urgent calls from the CEO (R1). How to use the password manager and MFA (R2).
B. Warehouse and operations	Lock or sign out of shared computers and never share login details (R2, R3). Protect delivery labels, shipping documents and customer information. Report suspicious calls, text messages or mistakes to a supervisor (R3).
C. Remote sales	Use a different password for each account, use the password manager and turn on MFA on mobile devices (R2). Lock devices, use public Wi-Fi safely and send customer information securely (R3). Watch out for fake customer or delivery messages and requests to change payment details (R1).

Audience	Topics (linked risk)
D. Head office general	How to identify phishing messages and use the Report button. How to use the password manager (R2). How to label and send protected customer information safely, and how to check email recipients before sending (R3).
E. Managers and executives	How to spot messages pretending to come from company leaders and fake payment approvals (R1). How to protect important accounts (R2). How to encourage staff to report problems without fear of blame.

Task 3: Deliver

3.1 Training methods for each staff group

Audience	Format	Why it fits
A. Finance	A 45-minute face-to-face workshop using safe examples of real fraud attempts. Give each employee a one-page payment-checking guide. Run extra phishing tests every three months and a practice fraud exercise in Month 9.	Finance staff face a high risk, and the group is small. Practising with realistic examples helps them build good habits. The checklist also guides them when making payments.
B. Warehouse	Supervisors give a 5 to 10-minute talk every month during shift meetings, covering all three shifts. Put posters and stickers near shared computers and in break rooms. Add a QR code linking to a 3-minute video.	This reaches staff who do not use email or sit at desks. It takes place during paid working hours, uses simple language and is led by people they know. It is also affordable to continue.
C. Remote sales	A 5-minute mobile lesson every month and a 30-minute Microsoft Teams session to explain how to use the password manager.	The lessons are short and can be completed on a phone between trips and customer visits.
D. Head office	A 20-minute online course at the start, followed by a 5-minute lesson each month and a short item in the company newsletter.	It is easy to deliver to a large group. Short lessons repeated regularly help staff remember the information.
E. Managers	A 30-minute talk during an existing management meeting, followed by a one-page update every three months.	It uses time already set aside for leadership meetings and encourages managers to lead by example.

3.2 Training for new employees

Every new employee completes a 20-minute “Security Essentials” session during their first week. The session explains the three main risks, how to report a problem and the no-blame promise. Warehouse employees receive the training in person from their supervisor. They also practise locking a shared computer. Within 30 days, employees receive extra training for their roles. This includes the finance payment-checking process, password manager setup for groups A, C, D and E, and safe data handling. HR adds the training to the new-starter checklist and reports completion every month.

3.3 How phishing tests will work

- All staff who use email take part in a phishing test every month. The test messages are based on common scams, such as fake supplier invoices, bank detail changes, delivery notices and password resets. Some tests will be easier than others. Finance staff receive extra payment-fraud tests every three months.
- Staff will be told in the company policy and launch message that phishing tests will take place. Managers and executives will also take part. The tests will not use upsetting messages about fake bonuses or job losses.
- Anyone who clicks a test link will see a short, 60-second lesson explaining what to look out for. Staff who click several times will have a private and friendly discussion with a Security Champion to help them improve. They will not be punished. Results will be shared as group totals by department and site, not as lists of individual names.
- Warehouse staff who rarely use email will use short “spot the scam” quiz cards during toolbox talks instead of email tests.

3.4 Reporting without fear of blame: “See it? Say it.”

- To report a suspicious email, use the Report button in Outlook on a computer or phone. To report a suspicious call, text message or mistake, tell your supervisor, contact the security hotline, or email security@northbridge [placeholder address]. The hotline will be available during business hours, and the SOC will handle reports outside those hours.
- Rule for Finance: If a bank detail change seems suspicious, stop the payment. Call the supplier using a phone number already saved in company records, then contact the security team.
- No-blame promise (approved by the COO): Staff will not be punished for honest mistakes if they report them quickly. This does not cover deliberate wrongdoing or repeated rule-breaking after coaching. Every person who reports an issue will receive a thank-you within one working day. Where possible, they will also be told what happened after the report.

Task 4: Measure results

The measures will show three things: reach (whether staff took part), behaviour (whether staff are making safer choices) and results (whether incidents are reducing). All results will be compared with the figures collected in Month 1.

Metric (type)	Calculation	Source	Owner	Review	What a change means
M1 Role training coverage (Reach)	Number of staff who completed their job-related training divided by the total number of staff in that group.	LMS; supervisor attendance sheets	HR L&D	Monthly	An increase means more staff are completing the training. It does not prove that their behaviour has changed.
M2 Phish report rate and credential-submission rate (Behaviour)	Number of phishing tests reported divided by the number delivered; number of login details entered divided by the number delivered.	Simulation tool	Security Awareness Lead	Monthly	More reports and fewer people entering their login details suggest that staff are spotting and reporting phishing messages. The difficulty of each test must also be considered.

Metric (type)	Calculation	Source	Owner	Review	What a change means
M3 Payment verification compliance (Behaviour)	Number of bank detail changes checked by phone divided by all changes reviewed.	AP change log audit	Finance Controller	Monthly	Directly checks whether staff are following the main safety step for R1. If the result is below 100%, the team should provide guidance and review the process.
M4 MFA and password manager adoption (Behaviour)	Number of eligible users who are enrolled and actively using the tools divided by the total number of eligible users.	Identity provider; password manager console	IT Ops Manager	Monthly	More staff using MFA and the password manager helps reduce the risk of password reuse (R2).
M5 Terminal spot-check pass rate (Behaviour)	Number of computers found locked divided by the total number checked.	Supervisor checklist	Site managers	Monthly	Checks whether warehouse staff are following the safety rules for R3.
M6 Human-driven incidents and losses (Outcome)	Number of incidents for each risk (R1/R2/R3), amount of money lost and the middle time taken to report a real phishing message.	Incident register; SOC	Security Awareness Lead / DPO	Quarterly	The goal is to reduce successful attacks and help staff report problems faster. Reports may increase at first because staff feel safer reporting issues. This does not always mean attacks have increased.

Reporting to leadership. Every three months, the Security Awareness Lead will send the COO and senior managers a one-page report. It will show whether each target is on track, using red, amber or green. It will also show progress compared with the starting figures, the three main findings and any decisions needed. These may include approving password manager licences or making phone checks compulsory before supplier payments. The report will also explain the limits of the results. For example, phishing tests may have different levels of difficulty, incident numbers may be low, survey answers depend on what staff say, and warehouse checks cover only selected terminals.

Task 5: Improve and continue the program

5.1 Reviews every three months (Months 3, 6, 9 and 12)

- Attendees: The Security Awareness Lead, Finance Controller, IT Operations Manager, Data Protection Officer, HR Learning and Development, two warehouse supervisors and two Security Champions (including one from sales). The Security Awareness Lead will lead the meeting. The COO will lead the meetings in Months 6 and 12.
- The team will review measures M1 to M6 and compare them with the starting figures and targets. They will also review incidents, near misses, phishing test results, staff feedback and new threats reported by the SOC.

- All decisions will be recorded in a shared action list. It will show what needs to be done, who is responsible, the deadline and the progress. The team will review this list at the next meeting. Changes to training materials will also be recorded.
- The program may be updated before the next review if there is a serious incident or near miss, a new scam is reported by the SOC, a process or system changes, a new law or regulation is introduced, a measure gets worse for two months in a row, or the same feedback is received from at least three sites.

5.2 Getting feedback from staff

After each training module, staff will answer two short questions: “Was this training useful for your job?” and “What should we change?” QR code feedback cards will be placed in break rooms for all shifts. Security Champions will also collect comments during night shifts. Each group of staff will have a 30-minute discussion every three months, with an option to give feedback anonymously. Feedback will be reviewed by department and shift. This will help make sure that training designed for sales staff is not used in the same way for warehouse staff.

5.3 Recognising good behaviour without embarrassing anyone

- “Good Catch” recognition: Every month, the company will thank staff who report useful security issues. Their names will be shared in the newsletter or at shift meetings only if they agree. They may also receive a small gift, such as a voucher. Staff who quickly report their own mistakes will receive a private thank-you from their manager.
- Team recognition, not individual rankings: Every three months, the COO will give a certificate to the site or team that has improved its reporting the most. The company will recognise teams that are doing well or improving. Staff will never be named or shamed for clicking a phishing test link.

5.4 Checking that each risk is covered

Risk	Audiences	Objective	Key activities	Metrics	Review decision example
R1 Invoice fraud	A, E, C	O1	Finance workshop, checklist, payment-fraud simulations, Month 9 tabletop	M3, M2, M6	Make phone confirmation a required step in the payment system if the result stays below 100%.
R2 Password reuse	All	O2	Password manager rollout, MFA prompts, onboarding	M4, M2, M6	Buy more password manager licences for warehouse supervisors.
R3 Data handling	B, C, D	O3	Toolbox talks, terminal stickers, data micro-modules	M5, M6, M1	Set shared computers to lock automatically at sites where fewer than 90% pass the checks.

Reflection

The most difficult part of the program was planning training for warehouse staff. They make up more than half of the workforce, but many do not use email often, spend little time at a desk and have limited access to online training. This means normal methods, such as online courses and email tests, may not reach them well. I chose short talks led by supervisors during shift meetings, as well as posters and reminders near shared computers. One challenge is that supervisors are not

security experts, so the information may be different from one site or shift to another. It may also be harder to prove who attended compared with online training records. I accepted this challenge because compulsory online training could show high completion rates without changing how people behave at work. To reduce the risk, I included short, prepared talks, Security Champions and checks of actual workplace behaviour. Another challenge was setting targets without having real starting figures. For this reason, I marked all targets as proposals. They will be reviewed and adjusted in Month 3 after the baseline results are available.

References

National Institute of Standards and Technology. (2024). Building a cybersecurity and privacy learning program (NIST SP 800-50 Rev. 1). U.S. Department of Commerce.

Verizon. (2024). 2024 Data breach investigations report. Verizon Business.

SANS Institute. (2024). Security awareness report: Managing human cyber risk. SANS Security Awareness.

GRC206 course materials. (2026). Security awareness program lifecycle: assess, plan, deliver, measure, improve and assignment handout.

Note: Northbridge Logistics is fictional. All staffing splits, systems and targets beyond the scenario are the author’s assumptions and proposals.

Program calendar: 12-month plan

Audiences: A Finance and procurement · B Warehouse and operations · C Remote sales · D Head office · E Managers and executives. Quarterly reviews are in bold. Month 1 = program start.

Month	Key activities	Audiences	Owner(s)	Measurement point
M1	Kick-off meeting with the sponsor; run the first phishing test and staff survey; review payment records; check shared computers; choose Security Champions.	All	COO; Security Awareness Lead (SAL)	Baseline captured (M2–M6, survey)
M2	Get approval for the no-blame promise; activate the Report button and hotline; launch new-staff training; brief managers.	E, All	SAL; HR L&D; COO	Baseline report to sponsor
M3	Give Security Essentials training to all staff; hold the finance fraud workshop and share the checklist; give the first warehouse talk about reporting; run phishing test 1.	All; A; B	SAL; Finance Controller; supervisors	M1, M2, M3 · Q1 REVIEW (recalibrate targets)
M4	Test the password manager with Finance and managers; begin the first stage of MFA enforcement; give the second warehouse talk about locking computers; run a phishing test.	A, E; B	IT Ops; supervisors	M4, M5 monthly
M5	Introduce the password manager to sales and head office staff; provide a short lesson on safe data handling; give the third warehouse talk; run a fake supplier invoice test.	C, D; B	IT Ops; DPO; SAL	Monthly metrics
M6	Run a mid-year staff survey; update training materials; begin the second stage of MFA enforcement.	All	SAL; IT Ops	Q2 REVIEW (COO chairs) + leadership dashboard
M7	Run a fake urgent CEO request and phone scam exercise for Finance; train sales staff on travel and public Wi-Fi safety; give the fourth warehouse talk; run a phishing test.	A, E; C; B	Finance Controller; SAL	Monthly metrics
M8	Train warehouse staff on protecting labels and shipping documents; carry out surprise checks of shared computers; run a phishing test.	B; D	DPO; site managers	M5 deep-dive
M9	Run a fraud practice exercise for Finance and managers; carry out the extra finance phishing test.	A, E	Finance Controller; SAL	O1 deadline · Q3 REVIEW
M10	Hold a “Good Catch” awareness week; share warnings about seasonal and busy-shipping scams; give the fifth warehouse talk; run a phishing test.	All	SAL; Champions; Comms	Monthly metrics; feedback focus groups

Month	Key activities	Audiences	Owner(s)	Measurement point
M11	Send Finance a year-end payment fraud warning; share reminders about holiday scams; run the final knowledge and staff culture survey.	A; All	Finance Controller; SAL	Survey vs baseline
M12	Review the full year's results; give recognition certificates; prepare the plan and budget for the next year.	E; All	COO; SAL	O2, O3 deadlines · Q4 REVIEW + annual report
Every month	Train new employees; run phishing tests for email users; give a short security talk to warehouse staff on every shift; recognise useful reports; send monthly results to the responsible managers.	All	HR L&D; SAL; supervisors	M1–M5 monthly; M6 quarterly

Workload note: the SAL’s time (about 50%) goes mainly on simulations, content and metrics. Warehouse delivery is shared across supervisors (10 minutes a month each) and Champions, which keeps the plan sustainable for a three-person team.